JADS

JM2030 CYBERSECURITY · GROUP 3

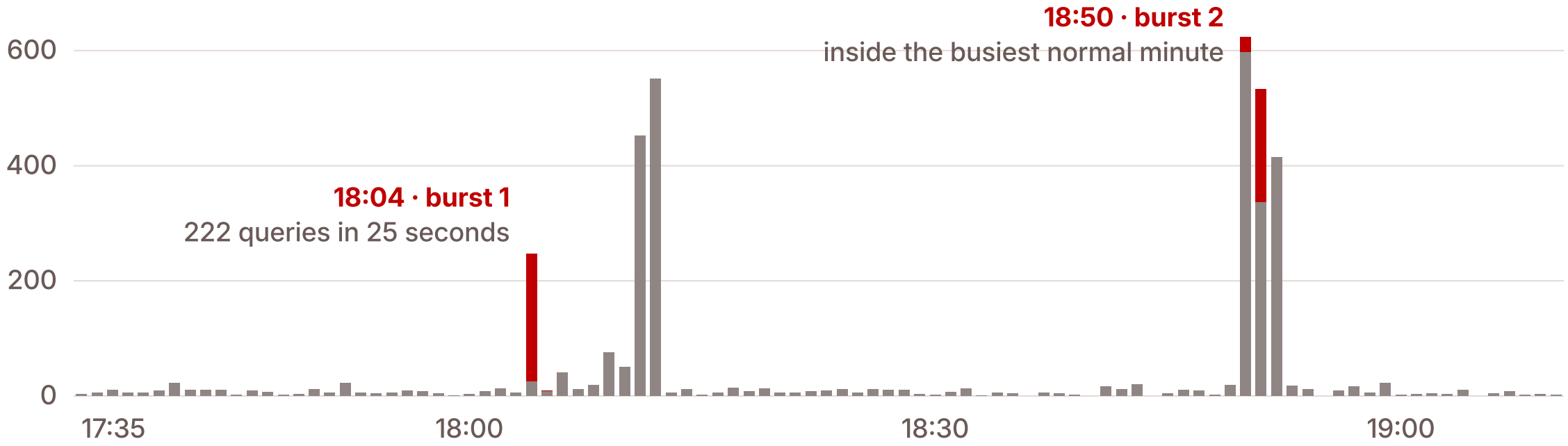
A tunnel hidden in DNS

Case 1: finding, dissecting and detecting a DNS tunnel with Isolation Forest

Gilbert Laanen · Rick de Rijk · Thom Verzantvoort
Tycho van Rooij · Samir Sabitli · Yannick Leroy

THE CASE

Can you spot the attack?

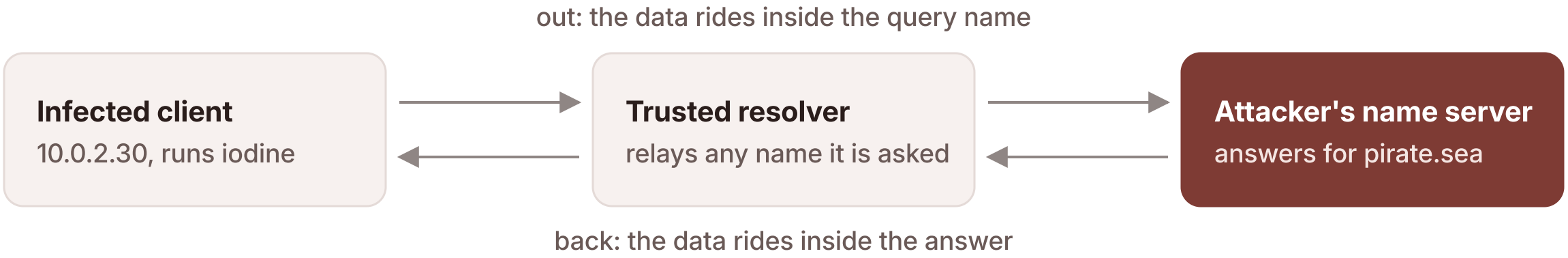


Volume points at the wrong machine: the busiest minute, **598 queries**, is ordinary browsing.

DNS queries per minute · 3,645 queries in dns.log · 7 January 2023, 17:35 to 19:10 UTC

THE PROTOCOL

DNS gets out of almost every network



Allowed out

DNS leaves almost every network and is rarely inspected.

Relayed for you

The resolver passes any name on to the server that owns the domain.

Never cached

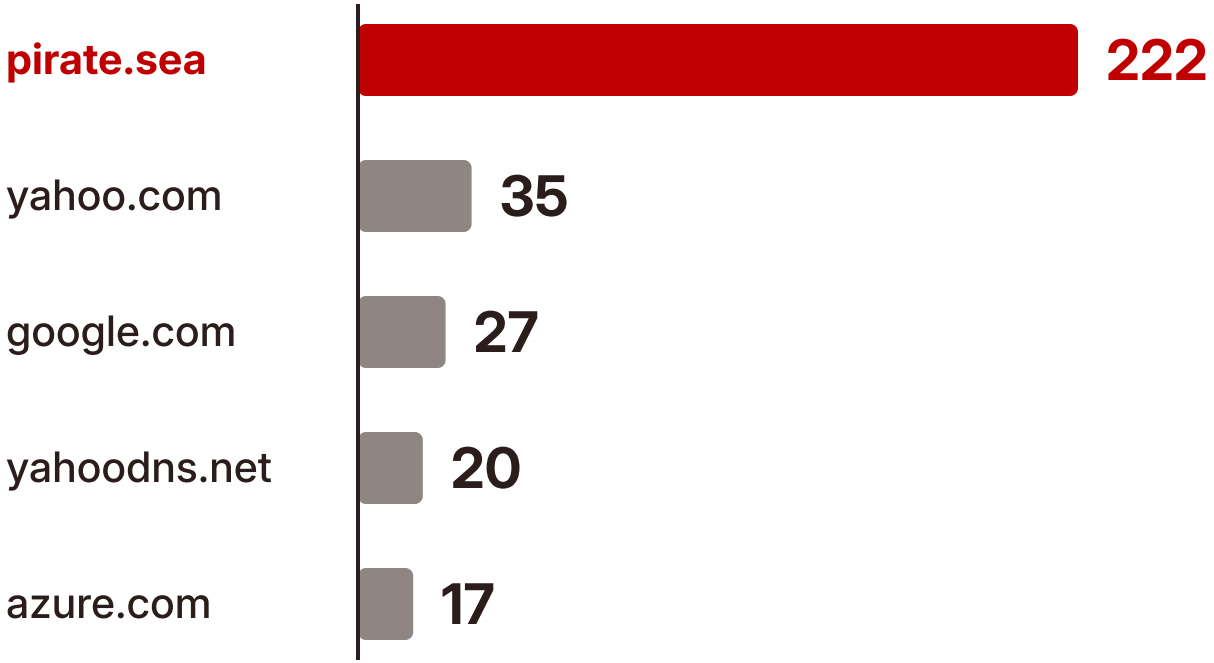
A repeated name never reaches the attacker, so every query needs a new name.

In our capture the client reached the tunnel server directly, on the same network segment.

DISCOVERY

One domain gives itself away

Unique query names per parent domain



- **6 times** more unique names than any other domain.
- Its longest name is **252 bytes**. DNS allows 255. The longest normal name is 103.
- The only domain asked for **NULL** records.
- Every query comes from one host, **10.0.2.30**, which asks for nothing else.

Name lengths counted in bytes on the wire, not as Zeek prints them.

NAMING THE TOOL

The tool is iodine

```
WIRESHARK · DNS.QRY.TYPE == 10

489  vaaaakardli.pirate.sea

490  answer: 56 41 43 4b 44 03 c5 e9 01  = VACK

495  zi03aA-Aaahhh-Drink-mal-ein-Jägermeister-

497  zi04aA-La-flûte-naïve-française-est-retirée-à-Crête
```

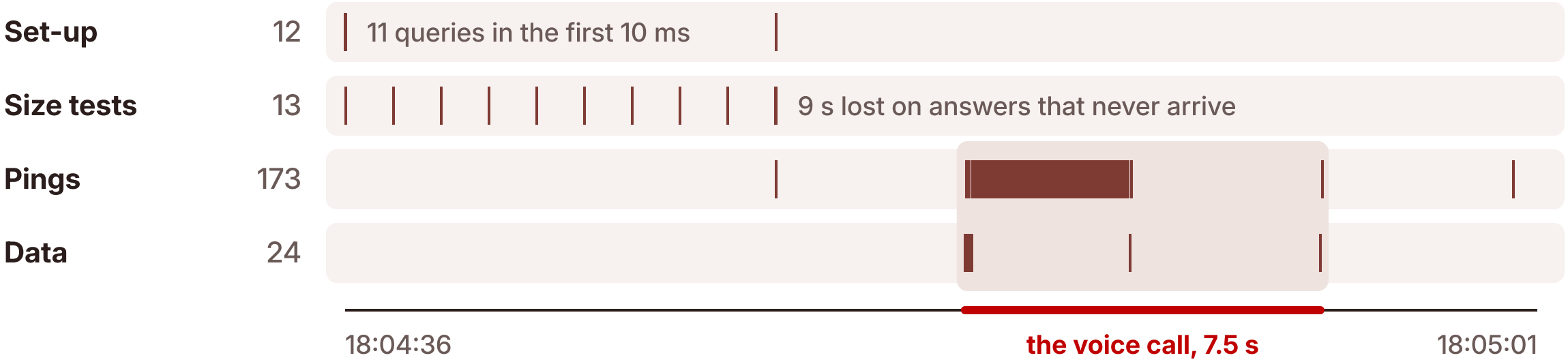
Four of the first frames of the session in case1.pcap.

1. **VACK**
   The first answer is iodine's version acknowledgement.
2. **Version 00000502**
   Decoded from the first query. It is the published protocol version.
3. **Built-in test sentences**
   The German and French strings are hard-coded in iodine's client.

MITRE ATT&CK lists iodine under T1572, Protocol Tunneling.

TIMELINE

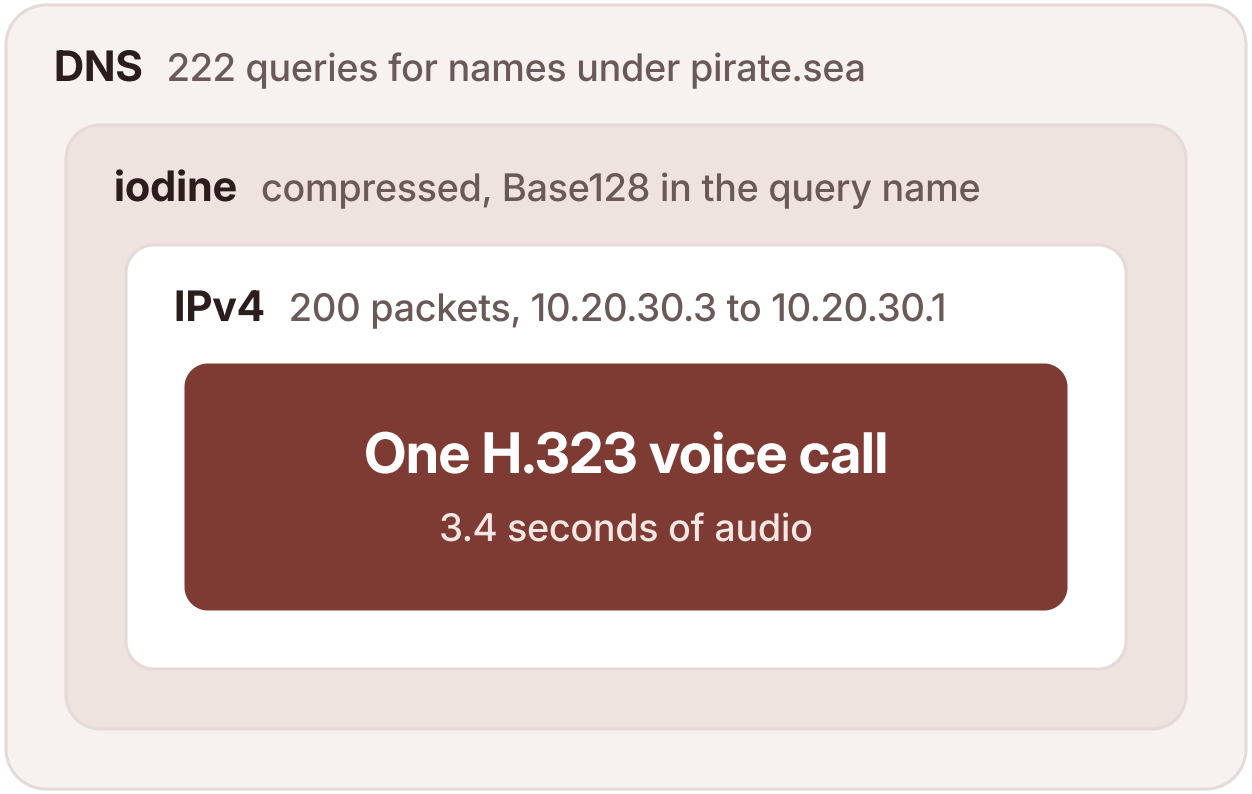
The whole session takes 25 seconds



18:50:50, the same 222 queries again. Identical byte for byte, down to the login challenge. A replay in the dataset, so one session and not two.

THE PAYLOAD

Inside the tunnel: one voice call



- An answering machine picks up. **169 audio frames** come down, 2 go up.
- **4.5 KB up**, 14.5 KB down. The upload is the call set-up.
- Each audio frame arrives as the answer to a ping.

No sign of data theft. The same channel could carry commands or stolen files.

Decoded from case1.pcap with the iodine protocol specification.

MITRE ATT&CK

Five techniques form one chain

RESOURCE DEVELOPMENT

T1588.002
Obtain a tool

A public tool, iodine

Inferred

T1583.004
Acquire a server

iodine server at 10.0.2.20

Inferred

COMMAND AND CONTROL

T1071.004
DNS as the channel

444 NULL queries over UDP 53

Observed

T1132.002
Non-standard encoding

iodine's own Base32 and Base128

Observed

T1572
Protocol tunnelling

Whole IP packets inside DNS

Observed

T1041 Exfiltration: not observed. Only 4.5 KB went up, all of it call set-up. The channel makes it possible.

ATTACK MECHANICS

What a tunnel cannot hide

Any DNS tunnel shows these

HARD TO CHANGE

- Many new names under one domain
- Long, random-looking names
- A steady stream of queries, even when idle
- Answers that carry data

Only this tool, or this lab

EASY TO CHANGE

- iodine's start-up letters and VACK
- Queries sent straight to the attacker
- One source port, TTL 0, EDNS0

173 of the 222 tunnel queries are short pings that look normal on their own. So the detector has to judge the domain, not the single query.